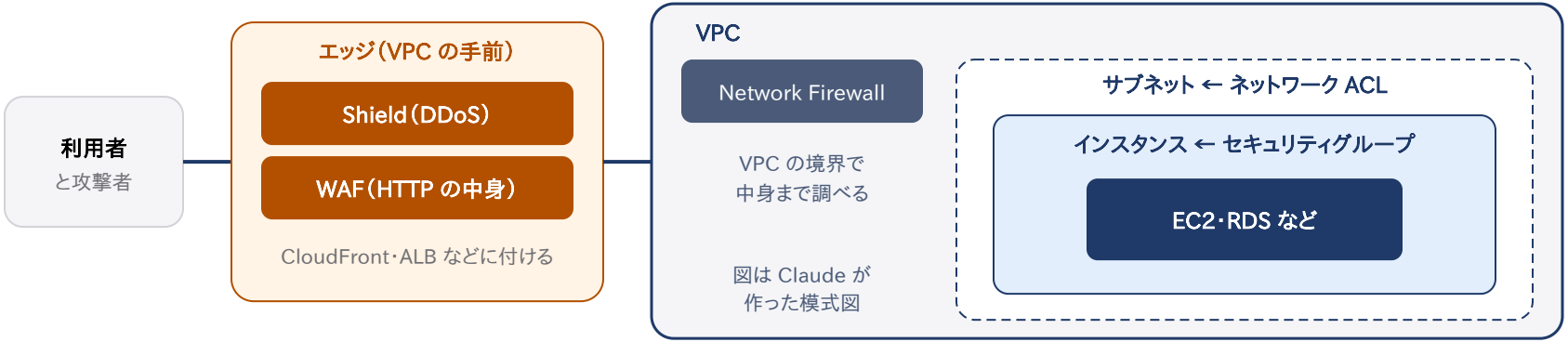
AWS SAA（SAA-C03）　分野1 セキュアなアーキテクチャの設計　#03

ネットワークのセキュリティ

VPC の中はサブネットとセキュリティグループで分けて守る。外からの攻撃は WAF と Shield で手前で止める

各ページの下に、根拠にした AWS の公式ドキュメント（Amazon VPC・AWS WAF・Shield・Firewall Manager・Network Firewall・Systems Manager）を書いた（青い文字を押すと開く）。「」の中はドキュメントの原文どおり（Network Firewall は英語版しかないので英語のまま）。会社名や構成の例は Claude が作った例

全体像 試験ガイド タスク 1.2



タスク 1.2 の知識・スキル（要約）	このPDF
VPC のセキュリティのしくみ（セキュリティグループ・ルートテーブル・ネットワーク ACL）	第1・2章
ネットワークのセグメント化（パブリックサブネットとプライベートサブネット）	第1章
外部の脅威からの保護（WAF・Shield・Firewall Manager など）	第3章

出典：AWS「コンテンツ分野 1: セキュアなアーキテクチャの設計」タスク 1.2

第1章

サブネットとセキュリティグループ

外に面するものだけを外に出す。残りはプライベートに置き、許可だけを書いて守る。

パブリックとプライベートはルートテーブルで決まる



	パブリックサブネット	プライベートサブネット
決め手	インターネットゲートウェイへの直接のルートがある	ない（外へ出るなら NAT デバイス経由）
置くもの	ALB・NAT ゲートウェイなど、外に面するものだけ	アプリサーバー・データベース。AWS のおすすめ

出典：サブネット（「AWS リソースを保護するために、プライベートサブネットを使用することをお勧めします。」）／Amazon VPC のインフラストラクチャセキュリティ（「インターネットからの直接アクセスを認めるべきでないインスタンスには、プライベートサブネットを使用します。」）

セキュリティグループの決まり

決まり	中身
付ける先	EC2 インスタンスなどのリソース（インスタンスレベル）。1つのリソースに複数付けられる
書けるルール	許可だけ。拒否は書けない
複数付けたら	ルールが集約されて1つのルールの集まりになる（許可の足し算）
戻りの通信	自動で許可（ステートフル）
料金	追加料金なし

AWS の位置づけ：VPC へのネットワークアクセスを制御する主な手段はセキュリティグループ。ネットワーク ACL は追加の防御の層。

最初の状態

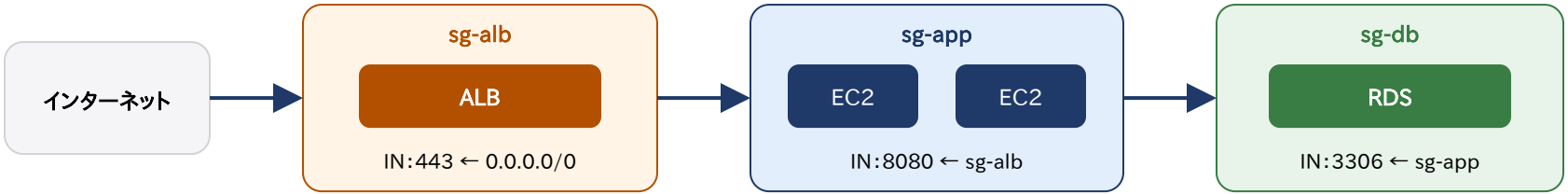
	インバウンド	アウトバウンド
新しく作った SG	ルールなし（何も入れない）	すべて許可
デフォルトの SG	同じ SG が付いたリソースからすべて許可	すべて許可

デフォルトのセキュリティグループはルールを変えられるが、削除はできない。

ひっかけ：「セキュリティグループで特定の IP を拒否する」はできない。拒否したいならネットワーク ACL（第2章）。

出典：セキュリティグループのルール（「許可ルールを指定できます。拒否ルールは指定できません。」）／Amazon VPC のインフラストラクチャセキュリティ（「VPC へのネットワークアクセスを制御するための主要なメカニズムとして」）／デフォルトのセキュリティグループ（「デフォルトのセキュリティグループを削除することはできません。」）

セキュリティグループを参照して層をつなぐ



送信元に IP ではなくセキュリティグループを書く。Auto Scaling で EC2 が増えても、新しい EC2 に sg-app が付けば自動で通る

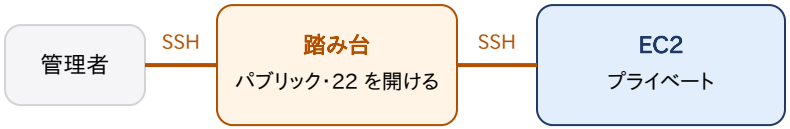
ポート番号と名前は Claude が作った例

聞かれ方	答え
DB にはアプリ層からだけ届くようにしたい（台数は変わる）	**DB の SG の送信元に、アプリ層の SG を指定**
Web サーバーに管理者の自宅 IP からだけ SSH させたい	**送信元に `203.0.113.1/32`（単一の IP は /32）**

出典：セキュリティグループのルール（「ルールのソースまたは宛先としてセキュリティグループを指定する場合、ルールはセキュリティグループに関連付けられているすべてのインスタンスに影響します。」）

管理のためのログイン：踏み台より Session Manager

踏み台ホスト（bastion）



ポートを開け、鍵を配り、踏み台自体も守る必要がある

Session Manager



インバウンドのポートを1つも開けない

	踏み台ホスト	Session Manager
インバウンドのポート	22 などを開ける	開けない
SSH キー	配って管理する	要らない
だれが入れるか	鍵を持つ人	IAM ポリシーで一元管理
記録	自分で仕組みを作る	セッションのログを S3 などに残せる

> **本番の言い回し：**「ポートを開けずに」「踏み台や SSH キーの管理なしで」「監査できるように」インスタンスに入る → Session Manager。

図は Claude が作った模式図。Session Manager を使うには、インスタンスに SSM Agent と、Systems Manager を使うための IAM の権限が要る。

出典：AWS Systems Manager Session Manager（「インバウンドポートを開いたり、踏み台ホストや SSH キーを管理したりする必要はありません」）

第2章

ネットワーク ACL

サブネットの出入口の、番号順で、戻りも見ない関所。拒否を書けるのはここ。

セキュリティグループとネットワーク ACL

特性	セキュリティグループ	ネットワーク ACL
効く単位	インスタンス（リソース）レベル	サブネットレベル
ルール	許可だけ	許可と拒否
評価のしかた	すべてのルールを見てから決める	番号の小さい順に見て、最初に一致したもので決める
戻りの通信	自動で許可（ステートフル）	明示的に許可が必要（ステートレス）
付け方	1つのリソースに複数付けられる	1つのサブネットに一度に1つだけ（1つの ACL は複数のサブネットに付けられる）
AWS の位置づけ	主な手段	きめの粗い補助の制御。特定の通信を拒否する、サブネットのガードレール

覚え方：SG は「人ごとの名札チェック（許可リスト）」、NACL は「建物の入口の番号順の関所」。両方を通らないと届かない。

どちらでも止められない通信：Route 53 Resolver（VPC+2 のアドレス）との DNS や、インスタンスメタデータなど。DNS の問い合わせを絞るなら Route 53 Resolver DNS Firewall。

出典：Amazon VPC のインフラストラクチャセキュリティ（比較表・「ステートレスできめの粗いネットワーク制御を行うことができます」）／ネットワーク ACL（「サブネットは一度に 1 つのネットワーク ACL にのみ関連付けることができます。」）

ルール番号：小さい順、最初の一致で決まる

例：Web サーバーのサブネットのインバウンド

番号	種類・ポート	送信元	動作
90	すべて	198.51.100.0/24	拒否
100	TCP 443	0.0.0.0/0	許可
110	TCP 1024-65535	0.0.0.0/0	許可
*	すべて	0.0.0.0/0	拒否

ルールは Claude が作った例。110 は、サーバーが外へ始めた通信の戻り（一時ポートあて）を通すためのもの。

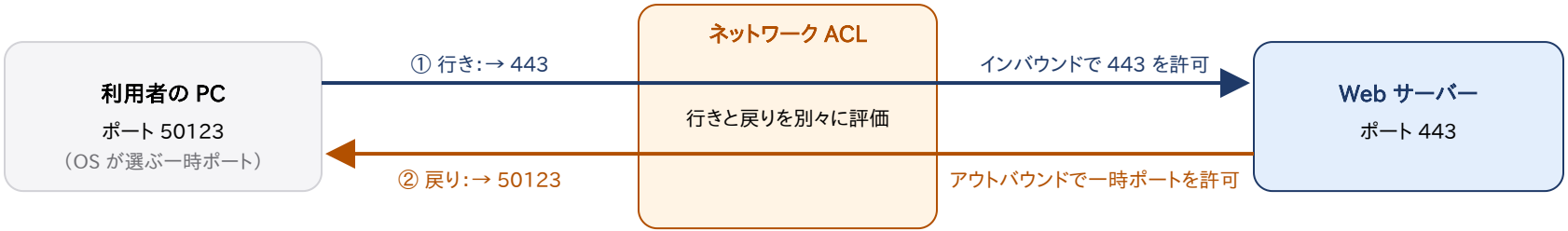
届いた通信	結果
198.51.100.9 から 443	90 で拒否（100 は見ない）
203.0.113.5 から 443	100 で許可
203.0.113.5 から 22	どれにも一致せず * で拒否

> **拒否は小さい番号に。**許可 100・拒否 200 の順だと、100 に先に一致して拒否が効かない。IAM の「明示的な Deny が勝つ」とは考え方が違う。

番号は 1〜32,766。後から間に挟めるよう、10 や 100 おきに付けるのが AWS のおすすめ。* のルールは消せない。

出典：ネットワーク ACL ルール（「ルールは、最も低い番号のルールから評価されます。ルールがトラフィックに一致すると、それと相反するより高い数値のルールの有無にかかわらず、すぐに適用されます。」）

ステートレスと一時ポート



セキュリティグループなら②は自動で通る。NACL は②のルールがないと戻れない。ポート番号は Claude が作った例

一時ポートを使う側	範囲
多くの Linux カーネル	32768〜61000
Windows Server 2008 以降	49152〜65535
Elastic Load Balancing・NAT ゲートウェイ・Lambda	1024〜65535

いろいろなクライアントを受けるなら、NACL では 1024〜65535 をまとめて開けることが多い。インスタンス自身がクライアントになる通信（更新の取得など）は、逆にインバウンドで一時ポートを開ける。

出典：ネットワーク ACL（「以前に送受信されたトラフィックに関する情報は保存されません」）／カスタムネットワーク ACL（一時ポート・「NAT ゲートウェイはポート 1024〜65535 を使用します。」）

デフォルトの ACL とカスタムの ACL

	デフォルトの NACL	カスタムの NACL
できるとき	VPC と一緒に自動で	自分で作る
最初の状態	**すべて許可**	**すべて拒否（* だけ）**
付くサブネット	ほかの ACL に関連付けていないサブネット（自動）	明示的に関連付けたサブネット

> **ひっかけ：**カスタムの NACL を作って付けただけで、そのサブネットは通信できなくなる。インとアウトの両方に、戻りの分も含めて許可を足す。

ネットワーク ACL が向いている場面

要件	NACL を使う理由
攻撃元の IP の範囲を、サブネット全体で止める	**拒否が書ける**
誤ったセキュリティグループで起動されたときの保険	**サブネット全体に効く**
データベースのサブネットには、アプリのサブネットからしか入れない	**サブネットのガードレール**

ネットワーク ACL のルールは、通信がサブネットに出入りするときに評価される。同じサブネットの中の通信には効かない。

出典：VPC のデフォルトのネットワーク ACL／カスタムネットワーク ACL（「これらのルールにより、パケットが他のどのルールにも一致しない場合は拒否されます。」）／ネットワーク ACL（「ネットワーク ACL ルールは、トラフィックがサブネット内でルーティングされるときではなく、サブネットに出入りするときに評価されます。」）

第3章

外からの攻撃への守り

DDoS は Shield、HTTP の中身は WAF、VPC の境界は Network Firewall。組織にまとめて配るのは Firewall Manager。

DDoS 攻撃の種類と Shield

層	攻撃の例
レイヤー 3（ネットワーク）	大量の通信で回線を埋める（UDP リフレクションなど）
レイヤー 4（トランスポート）	プロトコルを悪用して相手を疲れさせる（TCP SYN フラッドなど）
レイヤー 7（アプリケーション）	正しい形のリクエストを大量に送る（HTTP のフラッド）

> **入口を AWS のエッジに：**Route 53 のホストゾーン・CloudFront・Global Accelerator は、Shield Standard の効果が特に大きい。EC2 を直接さらすより強い。

	Shield Standard	Shield Advanced
料金	追加料金なし・自動	申し込む（有料）
守る層	よくある L3・L4	L3・L4 ＋ L7 の自動緩和
SRT の支援	なし	あり
コスト保護	なし	あり
WAF の料金	別にかかる	保護するリソースの標準の WAF の料金はふくまれる

Shield Advanced で守れるのは、CloudFront・Route 53 のホストゾーン・Global Accelerator・Elastic IP（EC2）・ALB などのインターネットに面したリソース。

出典：AWS Shield Standard の概要（「すべての AWS お客様は、Shield Standard の自動保護を追加料金なしで利用できます。」）／AWS Shield Advanced 機能とオプション（「DDoS 攻撃に起因する可能性のある AWS 請求の急増に対するコスト保護を提供します」）／AWS Shield と Shield Advanced の仕組み

AWS WAF：HTTP(S) のリクエストを見て止める

付けられる先（主なもの）

付けられる	付けられない
CloudFront ディストリビューション	Network Load Balancer
Application Load Balancer	EC2 インスタンスそのもの
API Gateway の REST API	VPC・サブネット
AppSync・Cognito ユーザープール など	

ウェブ ACL（新しいコンソールでは保護パック）

ルールを上から評価し、どれにも当たらなければデフォルトアクション（Allow か Block）。公開サイトは Allow にして悪いものだけ止める。ルールのアクションは許可・ブロック・カウント・CAPTCHA・チャレンジ。

ルールの種類	使いどころ
マネージドルールグループ	よくある攻撃のパターンを、自分でルールを書かずに防ぐ
SQL インジェクション・XSS	リクエストの中の悪意のある SQL やスクリプトを調べる
レートベース	同じ IP などから速すぎるリクエストを制限（L7 の DDoS・総当たり）
地理的一致	送信元の国や地域で扱い分ける
IP セット	決まった IP アドレスの一覧で許可・ブロック

SG・NACL では防げない：SQL インジェクションは正しい 443 番の通信の中身に入ってくる。ポートと IP しか見ないものでは区別できない。

出典：AWS WAF（「保護されたウェブアプリケーションリソースに転送される HTTP(S) リクエストをモニタリングできるウェブアプリケーションファイアウォールです」）／レートベースのルールステートメント（「レートベースのルールでは、受信リクエストをカウントし、レートが速すぎる場合にはリクエストを制限します。」）／デフォルトアクション

Firewall Manager・Network Firewall・DNS Firewall

サービス	何をするか	本番の言い回し
AWS Firewall Manager	WAF・Shield Advanced・セキュリティグループ・ネットワーク ACL・Network Firewall・DNS Firewall のルールを、組織の複数のアカウントとリソースにまとめて適用。新しいアカウントやリソースにも自動で付ける	「組織の全アカウントで」「新しいリソースにも自動で」
AWS Network Firewall	VPC のための、ステートフルなマネージドのファイアウォール兼 IDS/IPS。VPC の境界で通信をフィルター。Suricata 互換のルール・ドメイン名のリスト・ディープパケットインスペクション	「VPC から出る通信を許可したドメインだけに」「VPC の出入りを中身まで検査」
Route 53 Resolver DNS Firewall	VPC の中から Route 53 Resolver に送る DNS の問い合わせをフィルター	「悪いドメインの名前解決を止める」

WAF との違い：WAF は CloudFront・ALB などに届く HTTP(S) を見る。Network Firewall は VPC の出入りの通信全般（HTTP 以外も）を見る。

Firewall Manager は「配る係」：自分では通信を調べない。実際に止めるのは WAF や SG など。

出典：AWS Firewall Manager（「アカウントに追加されたリソースへの保護を自動的に追加します」）／What is AWS Network Firewall?（「Use custom lists of known bad domains to limit the types of domain names that your applications can access.」）

選び分け：この要件ならこれ

要件	答え
DB をインターネットから直接触れないところに置く	プライベートサブネット
DB にはアプリ層の EC2 からだけ入れる（台数が変わる）	SG の送信元に SG を指定
特定の IP の範囲をサブネット全体で拒否	ネットワーク ACL の拒否ルール（小さい番号）
ポートを開けず、鍵の管理なしでインスタンスに入る	Session Manager
SQL インジェクション・XSS を止める	WAF（ALB・CloudFront に付ける）
同じ IP からの大量のリクエストを自動で止める	WAF のレートベースのルール
DDoS で専門チームの支援と料金の補償がほしい	Shield Advanced
組織の全アカウントに同じ WAF のルールを自動で付ける	Firewall Manager
VPC から外へは許可したドメインだけに出す	Network Firewall

出典：このPDFの各ページの資料

まとめ

サブネット
パブリック=IGW への直接のルートあり。外に面するものだけ置く。残りはプライベート

セキュリティグループ
インスタンス単位・許可だけ・全部見て決める・ステートフル。SG を参照して層をつなぐ

ネットワーク ACL
サブネット単位・許可と拒否・小さい番号から・ステートレス（一時ポートを忘れない）

外からの攻撃
Shield=DDoS、WAF=HTTP の中身、Network Firewall=VPC の境界、Firewall Manager=まとめて配る

ひっかけ	正しくは
SG で特定の IP を拒否	**できない。NACL で**
NACL は拒否が優先	**番号順。最初の一致**
NACL で応答も自動で通る	**ステートレス。戻りを許可**
NLB に WAF を付ける	**付けられない**
Shield Standard を申し込む	**自動・追加料金なし**

> 次の #04 では、KMS・CloudHSM・ACM・Secrets Manager などの暗号化と秘密情報の扱いを学ぶ。

出典：このPDFの各ページの資料